

Penetration Testing Assignment Guide

A reusable command-by-command workflow for students completing the Week 4 black-box pentest exercise.

Scope: target domain only; no social engineering; no denial of service; use active testing only where written authorization applies.

This guide is for the authorized Mediroza training environment. Do not reuse active-testing commands against systems without explicit written permission.

Study/reference guide - September 2026

1. Assignment Roadmap

The supplied brief divides the exercise into four milestones: M1 initial access and retrieval of three confidential PDF lab reports; M2 recovery of the contents of the three protected files; M3 identification and documentation of the critical data exposure, including employee salaries and shareholder details; and M4 preparation of the professional penetration-testing report.

Milestone	Objective	Evidence to keep
M1	Reconnaissance, entry-point discovery, authentication/input testing, initial retrieval of the 3 confidential PDFs	HTTP requests, screenshots, retrieved files, and output of the 3 designed PDFs
M2	Analyze protection on the 3 files and recover their contents.	File metadata, hashes, tool output, successful-open evidence.
M3	Analyze recovered material for further exposure and summarize data exposure to the database.	Database table/diagram evidence, clean tables, screenshots.
M4	Write the final pentest report.	Executive summary, methodology, findings/evidence, risk ratings, recommendations.

2. Start With an Evidence Folder

Keep every result so the final report can show exactly what was observed.

```
mkdir -p ~/mediroza/{recon,nmap,web,burp,pdfs,evidence}
cd ~/mediroza
date | tee evidence/start-time.txt
```

3. Basic Web Reconnaissance

Begin with low-impact checks that identify DNS resolution, HTTP behavior, headers, technologies and possible web defenses.

DNS and HTTP checks

```
nslookup medirozahospital.com
curl -I http://medirozahospital.com/
curl -I https://medirozahospital.com/
curl -sS -L -o /dev/null -w 'HTTP: %{http_code} | final URL: %{url_effective} | redirects:
%{num_redirects}\n' http://medirozahospital.com/
curl -sS -L -o /dev/null -w 'HTTPS: %{http_code} | final URL: %{url_effective} | redirects:
%{num_redirects}\n' https://medirozahospital.com/
```

Page-title check

```
curl -sS http://medirozahospital.com/ | grep -io '<title>[^<]*</title>' | head -1
curl -sS https://medirozahospital.com/ | grep -io '<title>[^<]*</title>' | head -1
```

Technology and WAF checks

```
whatweb https://medirozahospital.com
wafw00f https://medirozahospital.com
dnsrecon -d medirozahospital.com
```

Save what the tools actually report. A challenge/interstitial page is evidence of the current HTTP response, not proof that the underlying application has been fully enumerated.

4. Nmap Scanning

Use Nmap to document reachable services on the authorized target. Version detection is useful context but is not, by itself, proof of a vulnerability.

```
nmap medirozahospital.com
nmap -sV medirozahospital.com
```

```
nmap -sV -oN ~/mediroza/nmap/service-scan.txt medirozahospital.com
```

Record the IP address, open ports, detected services/versions, TLS information and scan timestamp.

5. Web Content Enumeration With ffuf

Content discovery can reveal directories, files, login pages, backups or other entry points. Keep request volume reasonable and remain inside scope.

```
ffuf -u https://medirozahospital.com/FUZZ \  
-w /usr/share/wordlists/dirb/common.txt \  
-mc 200,204,301,302,307,401,403 \  
-o ~/mediroza/web/ffuf.json -of json
```

Review interesting results manually; a response code alone does not establish exploitability.

6. Burp Suite Workflow

Use Burp Suite as an intercepting proxy to understand how the application handles authentication, parameters and requests. Capture relevant traffic in Proxy/HTTP history and send selected requests to Repeater to compare controlled input changes.

For meaningful tests, preserve the original request, modified request, response difference and a screenshot. Useful observations include authentication responses, session cookies, redirects, hidden parameters, access-control behavior and input validation.

Do not use denial-of-service behavior, social engineering, or testing beyond the agreed target; those are explicitly excluded by the assignment.

7. M1 - Retrieving and Preserving the Assigned PDFs

Once the authorized exercise leads to the three assigned lab-report PDFs, preserve the originals before analysis.

```
cd ~/mediroza/pdfs
ls -lah
file *.pdf
sha256sum *.pdf | tee ../evidence/pdf-sha256.txt
pdfinfo file1.pdf
exiftool file1.pdf
```

Repeat metadata inspection for each file. Hashes establish exactly which artifacts were analyzed.

8. M2 - Analyzing Protected PDFs

First determine how each PDF is protected. The brief explicitly warns that one approach may not work for all three files.

```
pdfinfo file1.pdf
qpdf --show-encryption file1.pdf
exiftool file1.pdf
```

For the authorized lab files, a common workflow is to extract a password-verification hash and test it against an appropriate wordlist. Preserve tool output as evidence.

```
pdf2john file1.pdf > file1.hash
john --wordlist=/usr/share/wordlists/rockyou.txt file1.hash
john --show file1.hash
```

If protection differs between files, document the difference rather than forcing the same technique onto each artifact.

9. M3 - Investigating the Critical Data Exposure

M3 directs students to examine everything recovered so far, including file properties, because one finding points to a further critical exposure. Document the exact evidence chain that leads to the exposed data.

When a recovered SQL backup is part of the authorized evidence set, inspect it locally without changing it:

```
file mediroza_db_backup_2019.sql
wc -l mediroza_db_backup_2019.sql
grep -n -i 'salary|shareholder' mediroza_db_backup_2019.sql
sed -n '79,100p' mediroza_db_backup_2019.sql
```

The final command displays the shareholder INSERT records from the exercise results. Use grep first to locate relevant sections before choosing a line range.

10. Turning Raw SQL Into Deliverable Tables

Preserve the raw SQL as evidence, but present the required information as a readable table in the report.

ID	Shareholder	Share %	Shares	Class
1	Dr. Rajesh Naidoo	18%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15%	150,000	Ordinary
3	Dr. Johan van der Merwe	12%	120,000	Ordinary
4	Reddy Family Trust	11%	110,000	Ordinary
5	Thabo Molefe	10%	100,000	Ordinary
6	Sarah Botha	9%	90,000	Ordinary
7	Dr. Ahmed Kara	8%	80,000	Preferential
8	Naledi Zulu	7%	70,000	Ordinary
9	Michael Roberts	6%	60,000	Ordinary
10	Dr. Vikram Chetty	4%	40,000	Preferential
	TOTAL	100%	1,000,000	

For employee salary data, use the same approach: include only fields actually present in the recovered evidence, such as employee ID, name, role/department and salary. Do not invent missing fields.

11. Evidence Checklist for Every Finding

For each finding, preserve the discovery method, affected URL/file/service, original command or HTTP request, relevant output/response, screenshot, demonstrated impact and remediation.

Suggested screenshot naming

```
01-nmap-services.png
02-ffuf-discovery.png
03-burp-request.png
04-burp-response.png
05-pdf-metadata.png
06-pdf-recovered.png
07-sql-exposure.png
08-shareholder-data.png
09-employee-salary-data.png
```

12. M4 - Final Report Structure

Follow the report structure specified by the assignment.

Section	What to include
Executive Summary	Concise engagement overview, key findings and overall client risk.
Scope and Methodology	Target, tools, approach, authorization boundaries and limitations.
Findings and Proof of Exploitation	Each vulnerability, evidence and screenshots for the milestones.
Risk Rating	Critical/High/Medium/Low for each vulnerability with justification.
Recommendations and Remediation	Specific corrective actions for each identified issue.

13. Reusable Finding Template

Finding: [descriptive vulnerability name]

Affected asset: [URL/file/service]

Evidence: [command/request + screenshot reference]

Observation: [what the application/server did]

Impact: [what authorized testing demonstrated]

Risk: [Critical/High/Medium/Low + justification]

Remediation: [specific corrective action]

Retest: [how the fix should be verified]

14. Command Quick Reference

```
# Recon
nslookup medirozahospital.com
whatweb https://medirozahospital.com
wafw00f https://medirozahospital.com
dnsrecon -d medirozahospital.com

# HTTP
curl -I https://medirozahospital.com/
curl -sS https://medirozahospital.com/ | grep -io '<title>[^<]*</title>' | head -1

# Services
nmap -sV -oN nmap-service-scan.txt medirozahospital.com
```

```
# Content discovery
ffuf -u https://medirozahospital.com/FUZZ -w /usr/share/wordlists/dirb/common.txt \
-mc 200,204,301,302,307,401,403

# Local PDF evidence
file *.pdf
sha256sum *.pdf
pdftinfo file1.pdf
exiftool file1.pdf
qpdf --show-encryption file1.pdf

# Authorized lab password recovery
pdf2john file1.pdf > file1.hash
john --wordlist=/usr/share/wordlists/rockyou.txt file1.hash
john --show file1.hash

# Recovered SQL evidence
grep -n -i 'salary\|shareholder' mediroza_db_backup_2019.sql
sed -n '79,100p' mediroza_db_backup_2019.sql
```

15. Final Submission Check

Confirm that the report states authorization and scope, contains evidence for M1-M3, avoids unnecessary disclosure of confidential information, assigns and justifies a risk rating for each finding, provides actionable remediation, and matches every screenshot/evidence reference to the correct finding.

The goal is not merely to show commands. Explain why each command was used, what was observed, how the observation led to the next authorized step, and what weakness should be remediated.

Educational use: This guide is specific to an authorized training exercise. Active security testing must remain within written permission and agreed scope.